

Mão na Massa — Planejando Estratégias de Segurança da Informação do PI

Curso Técnico em Informática para Internet — IFSC Campus Florianópolis

Projeto:	QuizTime IFSC — Plataforma Web de Quizzes Gamificados para Apoio Docente
Equipe de desenvolvimento:	Rafael Agra e Vitor De Almeida Pereira
Período de desenvolvimento:	28/04/2026 a 20/12/2026

Foco	Estratégia	Detalhamento da estratégia	Tipos de ataque a prevenir
Peopleware	Hash de senha com bcrypt	As senhas de Professores e Alunos são armazenadas na tabela Usuario do MySQL já processadas pela função password_hash(\$senha, PASSWORD_BCRYPT) do PHP, nunca em texto puro. No login, o sistema usa password_verify() para comparar, sem nunca descriptografar. O bcrypt aplica salt automaticamente. Classificada em Peopleware porque mitiga diretamente o risco de comprometimento de credencial humana.	Ataque de força bruta; Ataque de dicionário; Vazamento de credenciais em caso de invasão do banco de dados
	MFA (autenticação multifator) restrita ao perfil Professor	Após validar usuário e senha, o sistema envia um código numérico de uso único para o e-mail cadastrado, liberando o acesso ao painel do Professor (CRUD de quizzes, exportação de notas) só após confirmação. O Aluno mantém login simples (1FA), já que o dano potencial de uma conta comprometida é bem menor.	Phishing; Roubo/vazamento de credenciais; Acesso não autorizado à conta administrativa mesmo com senha comprometida
	Política de senha forte no cadastro	O PHP valida via expressão regular que a senha tenha no mínimo 8 caracteres, combinando maiúscula, minúscula, número e caractere especial, antes de aplicar password_hash(). Cadastros fora da regra são recusados com mensagem orientativa.	Ataque de força bruta; Ataque de dicionário
	Mensagens educativas de conscientização na interface	Nas telas de Login e Cadastro, avisos fixos informam que o QuizTime IFSC nunca solicita senha por e-mail, WhatsApp ou SMS, além de orientação para não reutilizar senhas de outros serviços.	Phishing; Engenharia social
	Consentimento obrigatório via termo de uso (LGPD)	Na tela de cadastro, um checkbox obrigatório ("Li e aceito os Termos de Uso e a Política de Privacidade") impede o envio do formulário se não marcado. Uma página estática explica quais dados são coletados e sua finalidade, atendendo aos princípios de finalidade e transparência previstos na Lei Geral de Proteção de Dados (Lei nº 13.709/2018).	Tratamento irregular de dados pessoais; Exposição de dados sem consentimento válido do titular
	Orientação de uso pessoal da conta + log de tentativas	Reforço na mensagem de conscientização informando que a conta é pessoal e intransferível. A tabela TentativaQuiz registra o IP de origem e o timestamp de cada tentativa, permitindo ao Professor identificar padrões suspeitos de acesso compartilhado.	Uso indevido de credenciais legítimas (abuso de acesso autorizado)
	Recuperação de senha segura via token temporário	O fluxo de "esqueci minha senha" gera um token único com expiração curta (15 minutos), enviado por e-mail, permitindo definir nova senha sem nunca reenviar a senha antiga em texto claro. O token é invalidado após o primeiro uso.	Sequestro de conta via reset de senha; Reutilização de token de recuperação
	Revisão periódica de contas inativas/de teste	Contas sem login registrado por longo período, ou criadas apenas para testes durante o desenvolvimento, são revisadas e desativadas periodicamente.	Uso indevido de contas abandonadas; Acesso não autorizado via credenciais esquecidas

Foco	Estratégia	Detalhamento da estratégia	Tipos de ataque a prevenir
Hardwar e	Hospedagem em provedor de nuvem	O QuizTime IFSC é hospedado em um provedor de nuvem (ex.: AWS, Azure ou GCP), com instância de servidor para o PHP 8.x e serviço gerenciado de banco de dados para o MySQL 8.x, permitindo configurar firewall, backup e HTTPS de forma centralizada.	Indisponibilidade por falha de infraestrutura local; Falta de controle sobre atualizações de segurança do ambiente
	Backup automatizado diário com retenção	O banco de dados MySQL tem backup automático diário configurado, com retenção dos últimos 7 dias de snapshots, permitindo restaurar as tabelas Quiz, Pergunta, TentativaQuiz e ResultadoQuiz em caso de falha ou incidente.	Ransomware; Perda de dados por falha de hardware; Perda de dados por erro humano
	Firewall de rede restringindo portas expostas	O firewall virtual do provedor de nuvem libera publicamente apenas as portas 80 (HTTP) e 443 (HTTPS). A porta do MySQL (3306) permanece bloqueada para acesso externo, acessível apenas internamente pelo servidor da aplicação.	Varredura de portas (port scanning); Acesso direto não autorizado ao banco de dados; Força bruta contra o MySQL exposto
	HTTPS obrigatório com certificado Let's Encrypt	O servidor web tem certificado TLS gratuito via Let's Encrypt, com renovação automática, forçando redirecionamento de todo tráfego HTTP para HTTPS — cobrindo login, cadastro, envio de respostas e exportação de PDF.	Ataque de intermediário (man-in-the-middle); Interceptação de credenciais e dados em trânsito
	Rate limiting nas rotas críticas	O servidor limita requisições por IP em rotas sensíveis (máximo 10 por minuto para login e envio de resposta), retornando erro HTTP 429 para requisições excedentes, sem impactar o uso normal de uma turma respondendo simultaneamente.	Negação de serviço (DoS); Ataque de força bruta (login); Automação de envio de respostas
	Atualização periódica do sistema operacional e do PHP	O servidor mantém sistema operacional, PHP 8.x e MySQL 8.x atualizados com os patches de segurança mais recentes, corrigindo vulnerabilidades conhecidas antes que possam ser exploradas.	Exploração de vulnerabilidades conhecidas (componentes desatualizados); Malware
	Monitoramento com Sistema de Detecção de Intrusão (IDS) e logs de acesso	O servidor registra logs de acesso (tentativas de login, requisições administrativas, erros 403/429) e conta com um IDS (Sistema de Detecção de Intrusão) para identificar anomalias de tráfego, permitindo à equipe de desenvolvimento detectar padrões de ataque precocemente.	Detecção tardia de intrusão; Ataques não identificados por falta de monitoramento
	Ambiente de homologação segregado do ambiente de produção	Novas funcionalidades e correções são testadas em ambiente de homologação com dados fictícios, antes de serem publicadas em produção, onde ficam os dados reais de professores e alunos.	Exposição acidental de dados reais durante testes; Introdução de falhas não testadas em produção

Foco	Estratégia	Detalhamento da estratégia	Tipos de ataque a prevenir
Software	Uso consistente de Prepared Statements via PDO	Todas as consultas ao MySQL (login, busca de quizzes, cadastro de perguntas, envio de respostas) utilizam PDO com prepared statements e parâmetros nomeados, nunca concatenação direta de valores digitados na string SQL.	SQL Injection
	Verificação de autorização por perfil no backend (vertical)	Toda rota que executa ações administrativas (criarQuiz, editarQuiz, excluirQuiz, publicarQuiz, exportar PDF) verifica no servidor se o Usuario autenticado possui perfil = 'professor', retornando erro 403 para tentativas de um Aluno, mesmo sem o botão aparecer na interface. Trata-se de controle de acesso vertical — perfis diferentes com privilégios diferentes.	Broken access control (vertical); Escalonamento de privilégios; Acesso não autorizado a funcionalidades administrativas
	Validação de integridade da tentativa no servidor	Ao iniciar um quiz, o servidor grava dataInicio na tabela TentativaQuiz e recusa nova tentativa se já existir uma anterior. No envio de respostas, o tempo decorrido é calculado no PHP comparando dataInicio com o horário do servidor, nunca com valores enviados pelo navegador. O JavaScript permanece responsável apenas pela experiência visual.	Manipulação client-side (tampering); Ataque de intermediário; Fraude de resultado/ranking por múltiplas tentativas
	Sanitização de saída de dados com htmlspecialchars()	Todo dado do banco exibido em página HTML (enunciados, alternativas, título de quiz, nome de usuário, termo de busca) passa por htmlspecialchars() antes da renderização, via função central de "impressão segura" reutilizada em todas as telas.	Cross-site scripting (XSS) armazenado e refletido
	Verificação de vínculo Professor-Quiz + rastreabilidade no PDF exportado (horizontal)	Antes de gerar o relatório via TCPDF, o servidor verifica se o Quiz pertence ao Professor autenticado, recusando exportação de turmas de outros professores mesmo via manipulação de URL. Cada PDF inclui no rodapé identificação de quem exportou e data/hora. Trata-se de controle de acesso horizontal — mesmo perfil, dados de outro dono.	Broken access control (horizontal); Acesso indevido a dados pessoais de terceiros (LGPD); Vazamento sem rastreabilidade
	Verificação de vínculo à turma antes de exibir o ranking (horizontal)	Antes de retornar nomes e pontuações do ranking, o servidor verifica se o Aluno autenticado está vinculado àquela turma/curso. Alunos de turmas diferentes não visualizam dados uns dos outros, mesmo manipulando parâmetros da requisição.	Broken access control (horizontal); Exposição indevida de dados pessoais a terceiros fora do contexto pedagógico
	Proteção contra CSRF (Cross-Site Request Forgery)	Formulários que executam ações sensíveis incluem um token CSRF único por sessão, validado no servidor antes de processar a requisição, impedindo que sites maliciosos induzam o navegador do usuário autenticado a executar ações sem seu consentimento.	CSRF (Cross-Site Request Forgery)
	Gestão segura de sessão	O ID de sessão é regenerado após login bem-sucedido, cookies de sessão usam as flags HttpOnly e Secure, e a sessão expira automaticamente após período de inatividade.	Session hijacking; Session fixation; Roubo de sessão via XSS